Audit and Accountability Policy and Procedures (HPMG, practice document)

Nov 3, 2026 · @Musah

1. Document control

This policy sets how Harbor Point Medical Group (HPMG) logs, reviews and protects audit records. HPMG is a fictional organization, and the document exists only for assessment practice.

Item	Value
Document ID	HPMG-POL-AU-001
Version	1.0
Policy owner (designated official)	Information Security Officer (ISO)
Approved by	Chief Executive Officer (CEO)
Effective date	2026-11-04
Next scheduled review	2027-11-04
Classification	Internal
Related documents	HPMG-POL-AC-001 Access Control Policy and Procedures

Remediation note. This policy was written on 2026-11-03 to correct a finding from the DC01 assessment of 2026-11-01 to 2026-11-02 (POAM-009, control AU-2). No audit policy existed when the assessment was performed. This document is remediation, not evidence that a policy was in place during the assessment, and it does not change that finding. The finding closes only after the settings in Section 7 are applied and retested.

2. Purpose and scope

This policy makes sure HPMG can tell who did what on its systems, and can investigate after the fact. It supports the audit controls requirement of the HIPAA Security Rule (45 CFR 164.312(b)) and the NIST SP 800-53 Rev 5 Audit and Accountability (AU) family.

It applies at two levels: organization-level for all HPMG information systems, and system-level for DC01, a Windows Server 2022 domain controller for the ad.northstar.test Active Directory domain (NetBIOS name NORTHSTAR). It covers every employee, contractor and vendor who administers or relies on these systems.

The procedures in Section 7 apply to DC01 and to any domain controller added later.

3. Roles and responsibilities

The Information Security Officer is the designated official who manages development, documentation and dissemination of this policy and its procedures.

Role	Responsibilities
Chief Executive Officer	Approves this policy, funds log storage and review time, and receives reports of audit failures.
Information Security Officer (ISO)	Owns this policy. Reviews logs weekly, investigates alerts, keeps review records, and reviews the event list in Section 6 each year.
System Owner (Director of IT)	Accountable for DC01. Makes sure the settings in Section 7 stay applied and that log storage is large enough.
System Administrators	Apply and verify audit settings. Archive logs on schedule. Never clear, disable or edit logs without an approved ticket.
Compliance lead	Uses log review records for HIPAA risk analysis and audits.
All users	Know that activity on HPMG systems is logged. Report suspected misuse to the ISO.

4. Management commitment and coordination

HPMG executive leadership commits to keeping audit records complete, protected and reviewed. Audit failures, such as a log that stopped recording, are treated as business risks and reported to the CEO.

Logging only helps when several groups act together. HPMG coordinates as follows:

- **IT and Compliance:** Compliance tells the ISO which events HIPAA audits and risk analyses need. The ISO adds them to the event list in Section 6.
- **IT and HR:** HR names the people whose accounts need closer log review, such as those under investigation or on leave.
- **IT and Facilities:** Facilities shares badge and server room access records so they can be compared with logon records.
- **Vendors and contractors:** Contracts require vendors to allow logging of their access and to share relevant records.
- **Security governance:** The ISO, Director of IT and Compliance lead meet monthly. Audit alerts, gaps and open findings are on the agenda.

5. Compliance, enforcement and exceptions

This policy is written to be consistent with the HIPAA Security Rule (45 CFR 164.312(b) and 164.308(a)(1)(ii)(D)), applicable New York State requirements, contractual obligations, and NIST SP 800-53 Rev 5 and SP 800-53B as the organization's control baseline.

Enforcement. Tampering with logs, or turning off logging without approval, may lead to disciplinary action up to and including termination, and to contract termination for vendors. Suspected violations are reported to the ISO.

Exceptions. A person who cannot meet a requirement submits a written exception request to the ISO that states the reason, the risk and any compensating controls. The ISO and System Owner approve or deny it. Approved exceptions last no longer than 12 months and are recorded in the exception register.

6. Policy statements

HPMG commits to the following rules for all in-scope systems, including DC01.

1. **Logged event types.** The event types in the table below are logged on every in-scope system, continuously, for both success and failure unless stated otherwise.
2. **Rationale.** These events were chosen because they answer the questions an investigator asks after an incident: who tried to get in, who got in, what privileges they used, what they changed, and whether the evidence was tampered with. Each also supports the access control rules in HPMG-POL-AC-001 (rule 10: account creation, changes, privileged use and failed logons are logged).

3. **Review and update.** The ISO reviews this event list every 12 months and after any security incident, major system change, or assessment finding that shows a gap. Each review is recorded in the revision history.
4. **Log review.** The ISO reviews security logs weekly and investigates the alerts in Section 7.
5. **Time stamps.** Every system takes its time from a synchronized, authoritative source so records from different systems can be compared.
6. **Log protection.** Only System Administrators can read the full logs and only the ISO can approve clearing or reconfiguring them. Clearing a log is itself a logged, reviewed event.
7. **Capacity and retention.** Logs are kept 90 days online and archived for 6 years, in line with HIPAA documentation requirements. A log is never allowed to overwrite records that have not been archived.
8. **Failure of logging.** If logging stops or storage fills, administrators notify the ISO within one business day.

Event types to log

Event type	Windows audit subcategory	Setting
Successful and failed domain logons	Credential Validation; Kerberos Authentication Service; Kerberos Service Ticket Operations	Success and Failure
Successful and failed logons to the server	Logon; Special Logon	Success and Failure
Account lockouts	Account Lockout	Success and Failure
Account creation, change, disablement	User Account Management; Computer Account Management	Success and Failure
Privileged group changes	Security Group Management	Success and Failure
Use of administrator privileges	Sensitive Privilege Use	Success and Failure
Directory changes	Directory Service Changes	Success

Event type	Windows audit subcategory	Setting
Audit and authentication policy changes	Audit Policy Change; Authentication Policy Change; Authorization Policy Change	Success and Failure
Log tampering and system integrity	System Integrity; Security State Change; Other System Events	Success and Failure

7. Procedures for DC01

These procedures put Section 6 into practice for DC01 and the ad.northstar.test domain.

7.1 Apply the audit settings

1. A System Administrator opens the Group Policy Management Console and edits the GPO linked to the Domain Controllers OU ("LAB - DC01 Security Hardening").
2. Under Advanced Audit Policy Configuration, the administrator sets every subcategory in the Section 6 table to the stated value.
3. The administrator sets the Security event log maximum size to 1 GB and the retention method to archive the log when full, so records are not overwritten before they are archived.
4. The administrator runs `gpupdate /force`, then `auditpol /get /category:*` and saves the output with a hash as evidence of the applied settings.

7.2 Test that failures are recorded

1. From another computer, enter a wrong password for a test account on DC01 until the account locks.
2. On DC01, confirm the Security log shows credential validation failures (event 4776 or 4771) and the lockout (event 4740) with correct times and the source computer name.
3. File the screenshots or exports with the ticket. Repeat this test after any change to the audit GPO.

7.3 Weekly review

1. Each week the ISO reviews the Security log of every domain controller.
2. The ISO looks for these alerts and records each one with its cause:

    - Account lockouts (4740) and repeated failed logons (4771, 4776)
    - Additions to Domain Admins, Enterprise Admins, Schema Admins or Administrators (4728, 4732, 4756)
    - Use of sensitive privileges (4672, 4673)
    - Audit policy changes (4719) and a cleared log (1102)
3. Unexplained events are opened as security incidents under HPMG incident procedures.
4. The ISO signs the weekly review record, even when nothing was found.

7.4 Archive and protect logs

1. On the first business day of each month, an administrator exports the Security log to the protected archive share and records its SHA-256 hash.
2. Only the ISO and System Owner can change the archive share permissions.
3. Archives are kept for 6 years.

7.5 Records

The ISO keeps weekly review records, the event list review history, applied settings evidence, test results and the exception register for at least six years, in line with HIPAA documentation requirements.

8. Dissemination, review and approval

Dissemination. The ISO disseminates this policy and its procedures to system administrators and IT staff, system owners, department managers, Human Resources and Compliance staff. All other workforce members receive it through the annual security awareness acknowledgment.

1. The ISO publishes the current version in the intranet policy library under Security Policies.
2. The ISO emails the policy to the roles above whenever a new version is released.
3. Recipients acknowledge receipt in the learning management system. New hires acknowledge within 5 business days of their start date.
4. The ISO keeps the distribution list and acknowledgment report as the dissemination record.

Review and update. The ISO reviews this policy, its procedures and the event list every 12 months, and after any of these events:

- A security incident in which logs were missing or incomplete
- A major change to DC01 or the HPMG environment
- A change in law, regulation or contract requirements
- A finding from an assessment, audit or log review that shows a gap in this policy

Revision history

Version	Date	Author	Summary
1.0	2026-11-03	Information Security Officer	Initial release. Remediation for POAM-009 (AU-2).

Approval

Role	Name	Date approved
Information Security Officer	Daniel Okafor (fictional)	2026-11-04
Chief Executive Officer	Margaret Ellison (fictional)	2026-11-04

Approval recorded 2026-11-04, after the DC01 assessment. The approvers are fictional people in a fictional organization. This policy is remediation for POAM-009 and was not in place during the assessment.